



Finding useful and embarrassing information with Maltego

ANDREW MACPHERSON
ROELOF TEMMINGH

2017



Dealing the Perfect hand

Shuffling memory blocks on z/OS

CICSPwn: tool to pentest CICS middleware on a Mainframe (Remote code execution, access control bypass, etc.)

ELV.APF : script for escalating privileges using APF libraries on z/OS (Mainframe)

ELV.SVC : script for looking for « magic » syscalls and abusing them to achieve root (Mainframe)



Ayoub ELAASSAL



@ayoul3__

Github.com/ayoul3

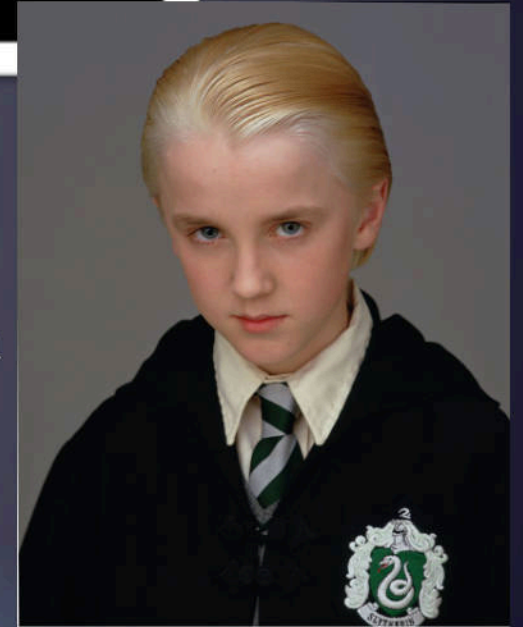
Agenda



- ▶ Intro
- ▶ Footprinting - the good the bad and the machines
- ▶ **Section One:**
 - ▶ Hunting ICS devices online in novel ways
- ▶ **Section Two:**
 - ▶ Hunting interesting organisations with Databreaches from their networks
- ▶ **Section Three:**
 - ▶ Identifying individuals at interesting locations
- ▶ Questions!
- ▶ Beer.

Who am I?

- ▶ Andrew MacPherson
- ▶ @AndrewMohawk
- ▶ 10 yrs at Paterva!
 - ▶ Andrew@Paterva.com
 - ▶ Employee number: 00000001
 - ▶ Tech support -> Webdev -> Win (@Paterva)
- ▶ B.Information Science degree (2006)
- ▶ With friends like mine... #draco malfoy #worstfriends #shamecon
- ▶ Something about someone with a Maltego hammer



Who was RT?



- ▶ Roelof Temmingh
 - ▶ roelof@paterva.com
- ▶ (co)Founder SensePost (2000)
 - ▶ Testing pens for 7 years
 - ▶ Building tools, writing books, doing talks
- ▶ Founder Paterva (2007)
 - ▶ Managing director
 - ▶ High level design
 - ▶ New features
- ▶ 14 x BlackHat, 5 x Defcon. Bluehat, Ekoparty, Cansecwest, Ruxcon, etc.
- ▶ DCC, UE, FIRST, GovCERT



What is Maltego?



- ▶ Tons of tutorials
- ▶ Videos too!



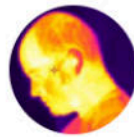
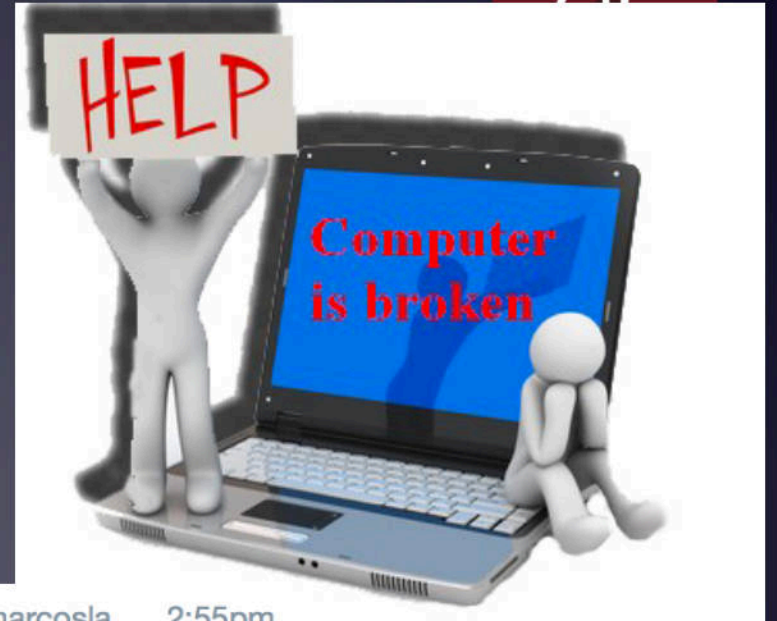
HERE BE DEMOS!

- ▶ Demo's rely on:

- ▶ Internet connection
- ▶ Code working
- ▶ Remote API's working
- ▶ Nothing to have changed

- ▶ Sacrifices have been made but if you could keep your fingers, toes and tongues crossed that would help!

- ▶ Or you are just gonna get pictures and interpretive dance



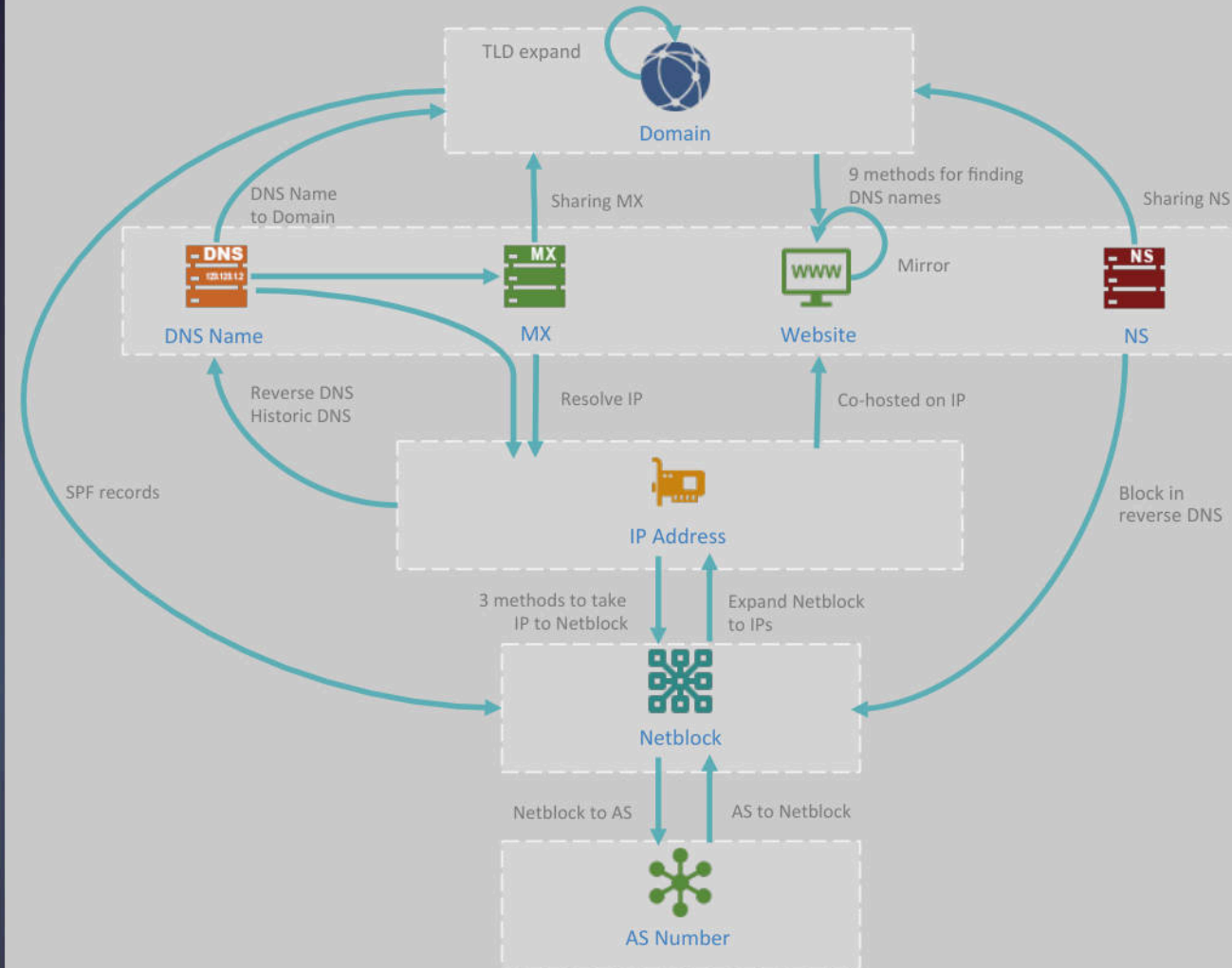
marco slaviero @marcosla... 2:55pm

Yeah, it ain't hacking if it's not spitting exceptions

...



Foot printing 101



Foot printing with code



```
machine("paterva.footprint.level3",
  displayName:"Footprint L3",
  author:"Roelof Temmingh",
  description:"This performs a level 3 (intense) footprint on a domain. It takes a while and it

start {

  paths {
    path {} //empty
    path {
      //two paths - NS and MX
      paths {
        //MX path
        path {
          log("MX path",showEntities:false)
          run("paterva.v2.DomainToMXrecord_DNS")
          userFilter(title:"Keep relevant MXes.",heading:"MX records",description:"P

          log("Getting domains for shared MX",showEntities:false)
          run("paterva.v2.MXrecordToDomain_SharedMX",slider:255)
          userFilter(title:"Select relevant domains.",heading:"Domains",description:

        }

        //NS path
        path {
          log("NS path",showEntities:false)
          run("paterva.v2.DomainToNSrecord_DNS")
          userFilter(title:"Keep relevant NS",heading:"NS records",description:"Plea

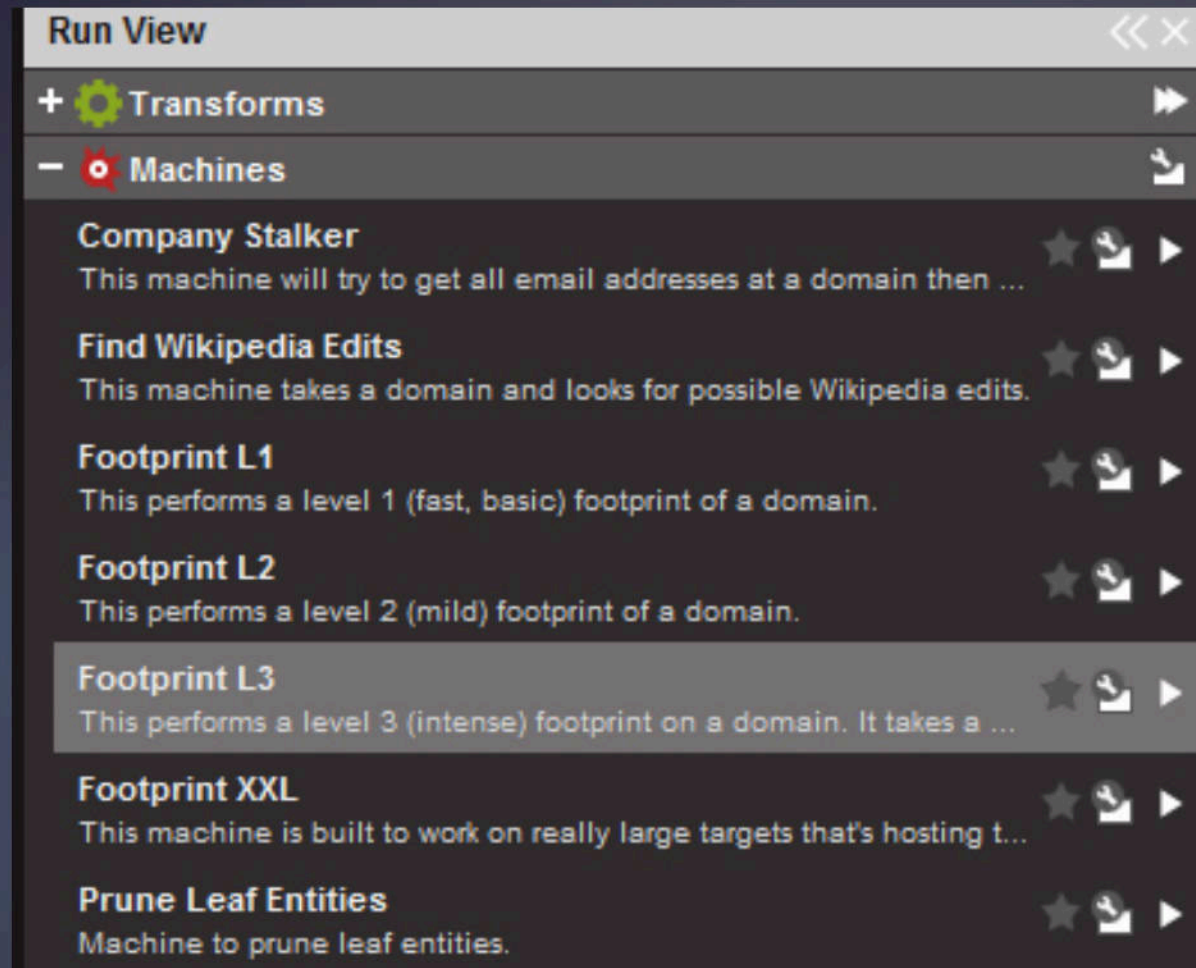
          log("Getting domains for shared NS",showEntities:false)
          run("paterva.v2.NSrecordToDomain_SharedNS",slider:255)
          userFilter(title:"Select relevant domains.",heading:"Domains",description:

        }
      }
    }
  }
}
```





Foot printing with Buttons



Footprinting

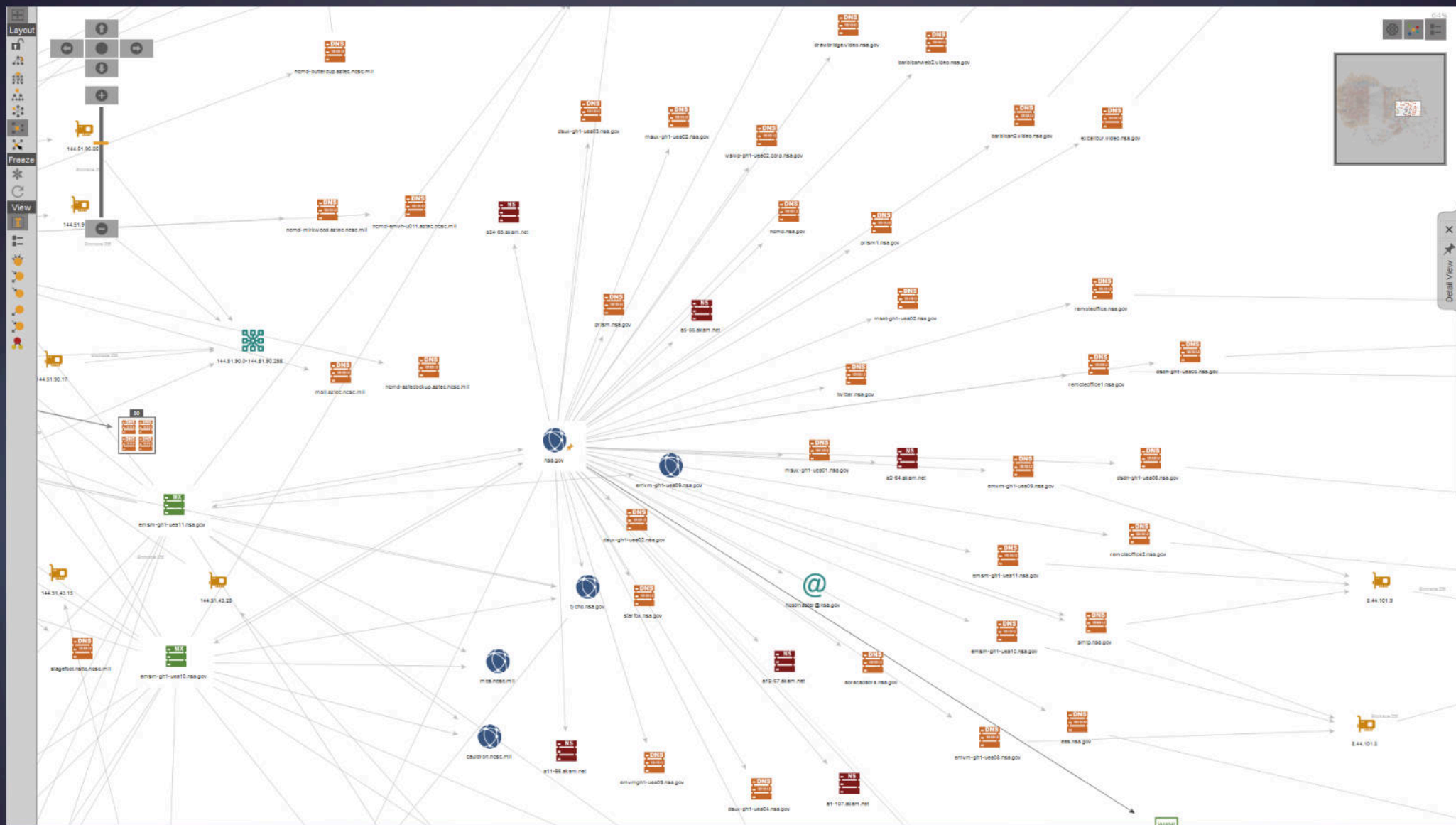


- ▶ Gives us:
 - ▶ Domains
 - ▶ DNS Names
 - ▶ IP Addresses
 - ▶ Netblocks
 - ▶ AS
- ▶ Basic information for targeting

Example



- ▶ Energy companies in Las Vegas
 - ▶ Nevada Energy seems to be the biggest
- ▶ NVEnergy.com footprint :)



ICS devices



- ▶ Industrial Control Systems
 - ▶ Used to operate / automate industrial processes
- ▶ Things like:
 - ▶ Power
 - ▶ Water
 - ▶ Manufacturing
 - ▶ Treatment
 - ▶ Etc
- ▶ Systems you don't want to break/fall over

Hacking ICS devices



- ▶ Not for this talk
- ▶ Many talks / Tweets / youtubez
- ▶ Targeting
 - ▶ Devices
 - ▶ Firewalls
 - ▶ Protocol
 - ▶ Etc
- ▶ Mostly deal with having access to the device
 - ▶ But what if you need to find it first?

The screenshot shows a YouTube video player with the title "Hacking PLC with metasploit" by Ozkan Erdogan. The video content displays a Metasploit terminal session and a Modbus client interface. The terminal session shows the following commands and output:

```
root@kali: ~  
root@kali: ~  
msf auxiliary(modbusclient) > show options  
Module options (auxiliary/scanner/scada/modbusclient):  
  
Name          Current Setting  Required  Description  
-----  
DATA          DATA            no        Data to write (WRITE_COIL and WRITE_REGISTER modes only)  
DATA_ADDRESS  DATA_ADDRESS    yes       Modbus data address  
RHOST         RHOST           yes       The target address  
RPORT         RPORT           yes       The target port  
UNIT_NUMBER   UNIT_NUMBER      no        Modbus unit number  
  
Auxiliary action:  
  
Name          Description  
-----  
READ_REGISTER Read one word from a register  
  
msf auxiliary(modbusclient) > set action READ_REGISTER  
action => READ_REGISTER  
msf auxiliary(modbusclient) > use auxiliary/scanner/scada/modbusclient
```

The Modbus client interface shows a table of holding registers:

Address	Value	Name	Binding
10			
20			
30			
40			
50			
60			
70			
80			
90			
100			
110			
120			
130			

The video player shows 2,881 views and was published on 15 Dec 2015. The description reads: "Reading and writing on register and coil values using metasploit auxiliary modules of scada. These coil values usually represent the on/off position for critical valves, engines, ignition systems in industrial control systems (Scada)".

ICS Devices ... on the Internet?



- ▶ They have networking
- ▶ Most advise to keep them in an airgapped lan / offline
- ▶ Major Protocols:
 - ▶ Modbus
 - ▶ S7
 - ▶ (Niagara) Fox
 - ▶ BACnet
- ▶ But hopefully there are none online ...right?

Protocols

The following protocols are some of the languages that the industrial control systems use to communicate across the Internet. Many of them were developed before the Internet became widely used, which is why Internet-accessible ICS devices don't always require authentication - it isn't part of the protocol!

 Modbus is a popular protocol for industrial control systems (ICS). It provides easy, raw access to the control system without requiring any authentication. Explore Modbus	 S7 (S7 Communication) is a Siemens proprietary protocol that runs between programmable logic controllers (PLCs) of the Siemens S7 family. Explore Siemens S7	 DNP3 (Distributed Network Protocol) is a set of communications protocols used between components in process automation systems. Its main use is in utilities such as electric and water companies. Explore DNP3
 The Fox protocol, developed as part of the Niagara framework from Tridium, is most commonly seen in building automation systems (offices, libraries, Universities, etc.) Explore Niagara Fox	 BACnet is a communications protocol for building automation and control networks. It was designed to allow communication of building automation and control systems for applications such as heating, air-conditioning, lighting, and fire detection systems. Explore BACnet	 EtherNet/IP was introduced in 2001 and is an industrial Ethernet network solution available for manufacturing automation. Explore EtherNet/IP
 Service Request Transport Protocol (GE-SRTP) protocol is developed by GE Intelligent Platforms (earlier GE Fanuc) for transfer of data from PLCs. Explore GE-SRTP	 The HART Communications Protocol (Highway Addressable Remote Transducer Protocol) is an early implementation of Fieldbus, a digital industrial automation protocol. Its most notable advantage is that it can communicate over legacy wiring. Explore HART-IP	 PCWorx is a protocol and program by Phoenix Contact used by a wide range of industries. Explore PCWorx
 MELSEC-Q Series use a proprietary network protocol for communication. The devices are used by equipment and manufacturing facilities to provide high-speed, large volume data processing and machine control. Explore MELSEC-Q	 FINs, Factory Interface Network Service, is a network protocol used by Omron PLCs, over different physical networks like Ethernet, Controller Link, DeviceNet and RS-232C. Explore OMRON FINs	 The protocol the Crimson v3.0 desktop software uses when communicating with the Red Lion Controls G306a human machine interface (HMI). Explore Crimson v3

Finding ICS devices on shodan



- ▶ Google Hacking-esque
- ▶ Multiple search strings
 - ▶ “port: 9600 response code”
 - ▶ “port:2404 asdu address”
- ▶ Results give
 - ▶ IP Addresses
 - ▶ Types (CPU / Model / etc)
 - ▶ “Locations”

The screenshot shows the Shodan search engine interface. The search bar contains the query "port:9600 response code". The results are categorized into several sections:

- TOTAL RESULTS:** 1,109
- TOP COUNTRIES:** A world map showing the distribution of results by country. The top countries listed are Spain (209), France (136), Canada (126), United States (92), and Italy (79).
- TOP ORGANIZATIONS:** A list of organizations with their respective result counts: Telefonica de Espana (128), Orange (100), ANTENNA HUNGARIA Magyar Műsorszóró és Rádió (45), Telecom Italia Business (20), and HiNet (19).
- TOP OPERATING SYSTEMS:** Linux 2.4-2.6 (2).
- TOP PRODUCTS:** CJ2M-CPU33 (181), CJ2M-CPU31 (120), CJ1M_CPU13 (94), CJ1M_CPU11 (93), and CJ2M-CPU32 (87).

Three specific results are highlighted on the right side of the page:

- 194.140.169.200:** Vodafone Ono, Spain. Added on 2017-07-11 18:07:45 GMT. Response Code: Success (0). Controller Model: CJ2M-CPU32. Controller Version: 02.01. For System Use: Program Area Size: 20. IOM Size: 23. Number of DM Words: 32768. Timer/ Counter: 8. Expansion DM Size: 1. Number of Steps/ Transitions: 0. Memory Card Type: No memory card. Memory Card Size: 0.
- 92.245.90.48:** Invitech Megoldások Zrt., Hungary, Hajdúböszörmény. Added on 2017-07-11 17:58:40 GMT. Response Code: Success (0). Controller Model: CJ2M-CPU31. Controller Version: 01.20. For System Use: Program Area Size: 10. IOM Size: 23. Number of DM Words: 32768. Timer/ Counter: 8. Expansion DM Size: 1. Number of Steps/ Transitions: 0. Memory Card Type: No memory card. Memory Card Size: 0.
- 80.15.56.94:** LPuteaux-050-1-81-04.w80-15.abo.wanadoo.fr, France. Added on 2017-07-11 17:44:04 GMT. Response Code: Success (0). Controller Model: CJ2M-CPU32. Controller Version: 02.00. For System Use: Program Area Size: 20. IOM Size: 23. Number of DM Words: 32768. Timer/ Counter: 8.

Hunting ICS Devices



- ▶ Find all ICS devices
 - ▶ Try and do attribution
 - ▶ Is it our target? Yes/No
- ▶ **This doesn't really work**
 - ▶ So many different devices/types
 - ▶ None of them say “NVEnergy main powerplant”

```
port:502#Modbus
port:102#Siemens S7
port:20000 source address#DNP3
port:1911,4911 product:Niagara#Niagara Fox
port:47808#BACnet
port:44818#EtherNet/IP
port:18245,18246 product:"general electric"#GE-SRTP
port:5094 hart-ip#HART-IP
port:1962 PLC#PCWorx
port:5006,5007 product:mitsubishi#MELSEC-Q
port:9600 response code#OMRON FINS
port:789 product:"Red Lion Controls"#Crimson v3
port:2455 operating system#Codesys
port:2404 asdu address#IEC 60870-5-104
port:20547 PLC#ProConOS
```

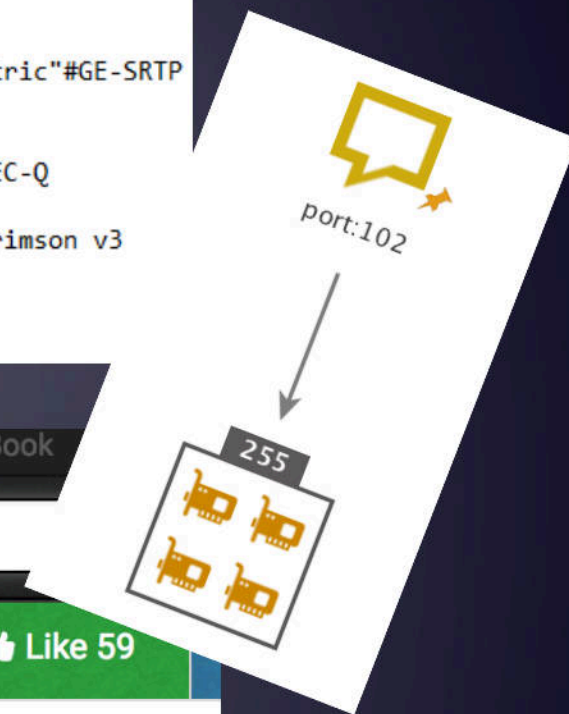
Shodan Developers Book

SHODAN port:502

Exploits Maps Like 59

TOTAL RESULTS

15,122



Hunting ICS devices with Maltego and Shodan



- ▶ There are many types of ICS
 - ▶ Instead of doing one lets do all of them at once
 - ▶ Build “super transform” to find them all
- ▶ ? + Search strings
 - ▶ Domain
 - ▶ Netblock (net: cidr)
 - ▶ +whatever shodan keywords

```
port:502#Modbus
port:102#Siemens S7
port:20000 source address#DNP3
port:1911,4911 product:Niagara#Niagara Fox
port:47808#BACnet
port:44818#EtherNet/IP
port:18245,18246 product:"general electric"#GE-SRTP
port:5094 hart-ip#HART-IP
port:1962 PLC#PCWorx
port:5006,5007 product:mitsubishi#MELSEC-Q
port:9600 response code#OMRON FINS
port:789 product:"Red Lion Controls"#Crimson v3
port:2455 operating system#Codesys
port:2404 asdu address#IEC 60870-5-104
port:20547 PLC#ProConOS
```


Hunting ICS Devices



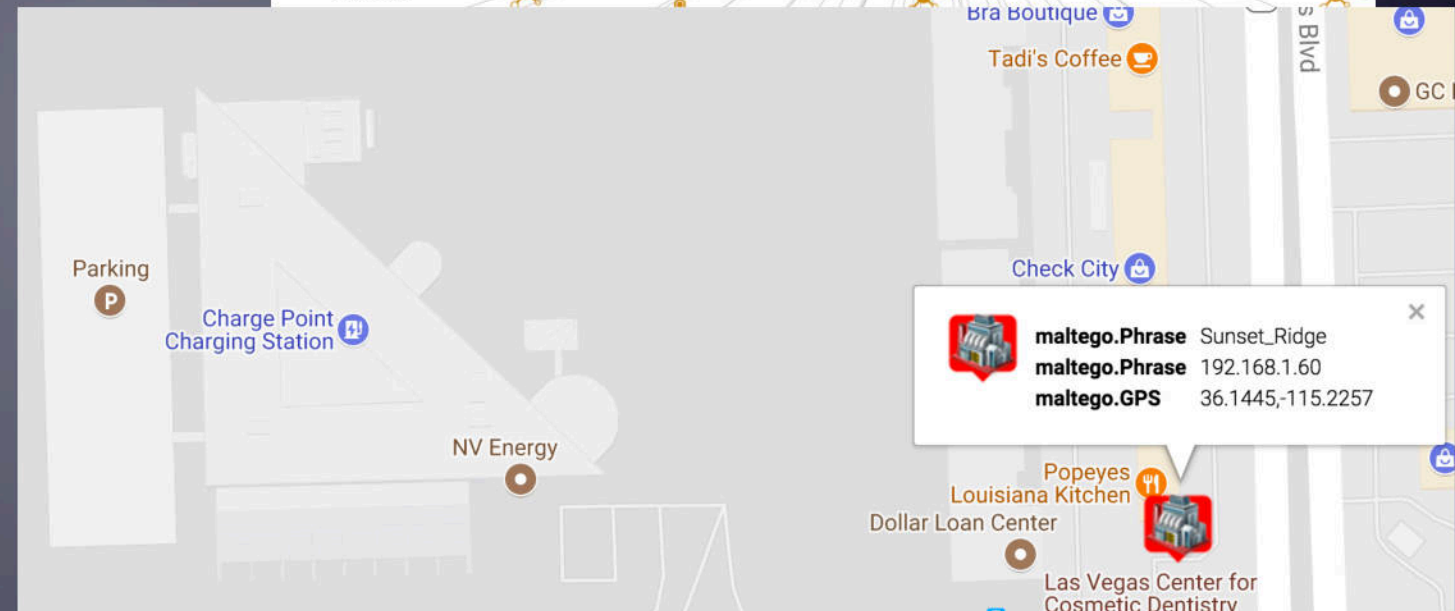
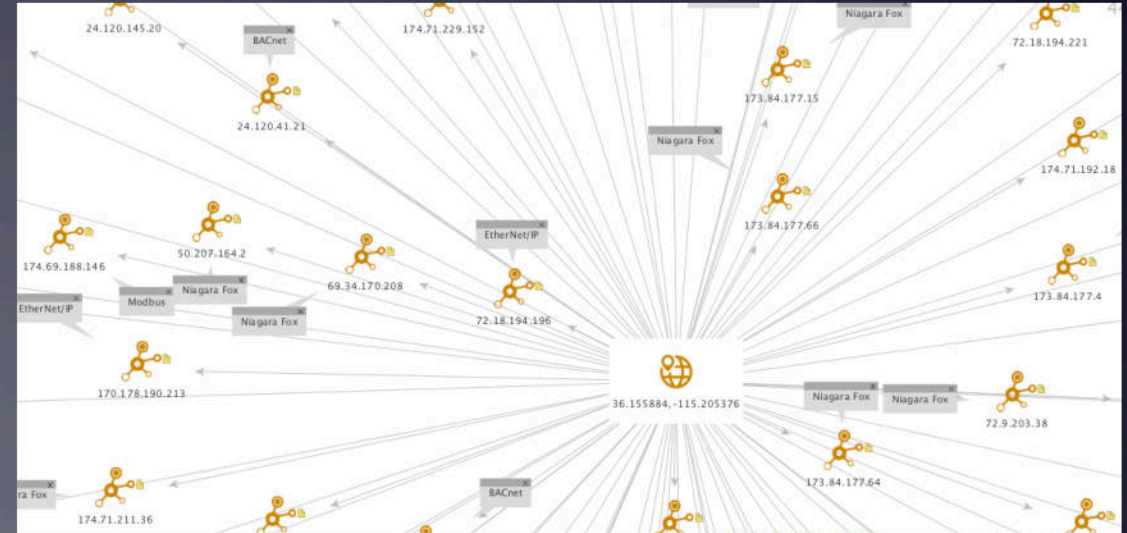
- ▶ Instead of finding all, lets feed inputs:
 - ▶ Domain/Netblock/IP
 - ▶ Woohoo! Footprinting!
- ▶ **This doesn't really work either!**
 - ▶ Nothing in NVEnergy?
- ▶ Sometimes you do find it:
 - ▶ Princeton.edu
 - ▶ Usc.edu



Hunting ICS Devices

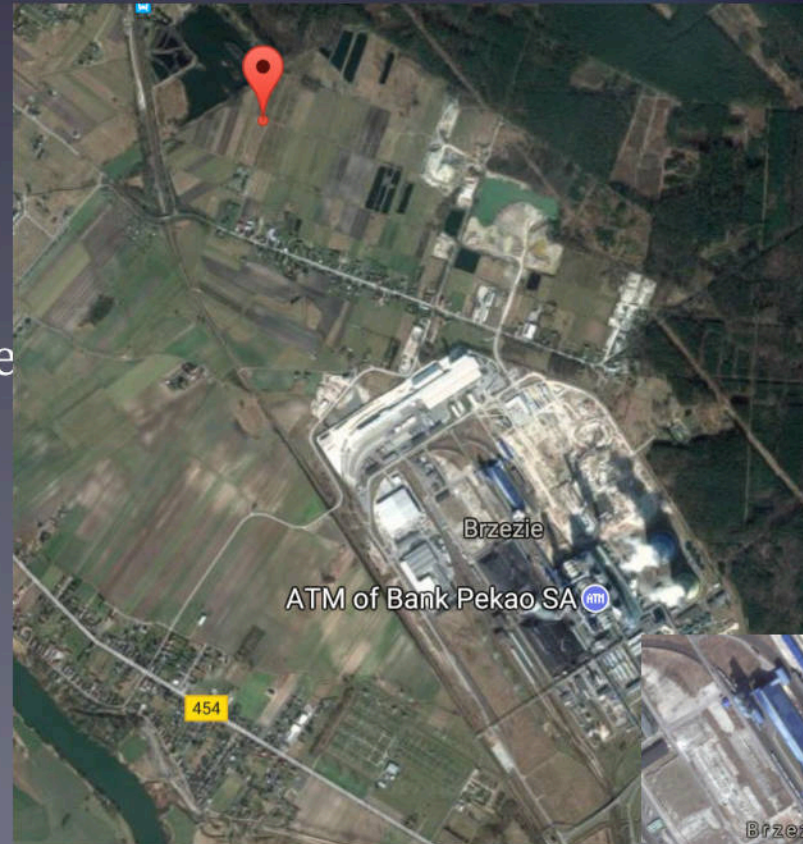


- ▶ Okay so footprinting is out, what about other inputs:
 - ▶ Geo-location?
- ▶ GPS near target->ICS
 - ▶ Example: Las Vegas!
- ▶ Better results
 - ▶ Manual
 - ▶ Lucky



Hunting ICS Devices

- ▶ Manually finding it is a pain in dense area
- ▶ Isolated area?
- ▶ 50.754101, 17.881712
 - ▶ 3km



Hunting ICS Devices

- ▶ One power plant/GPS works okay
 - ▶ What if we want all of them?
 - ▶ How do we find their locations?
- ▶ GEONAMES!
- ▶ Can find places (and their co-ordinates) based on categories like:
 - ▶ Power
 - ▶ Water
- ▶ ...you see where this is going

The screenshot shows the GeoNames website interface. At the top, the GeoNames logo is displayed. Below it, a text description states: "The GeoNames geographical database covers all countries and contains over eleven million placenames that are available for download free of charge." The search interface includes a search bar, a dropdown menu set to "all countries", and buttons for "search", "show on map", and a link to "advanced search". A prompt below the search bar says "enter a location name, ex: 'Paris', 'Mount Everest', 'New York'".

Overlaid on the screenshot is a diagram illustrating a workflow. It starts with a yellow speech bubble icon labeled "power". An arrow points from this icon to a circular node labeled "power station(PS)" which contains a blue gear icon. From this node, an arrow points down to a box containing four globe icons and the number "48". Another arrow points from the "power" icon to a window titled "Required inputs". This window displays the text "The following transforms require inputs:" followed by a section titled "To GeoNames Location". Under this section, there is a field labeled "* Country Code" with the value "pl" entered.



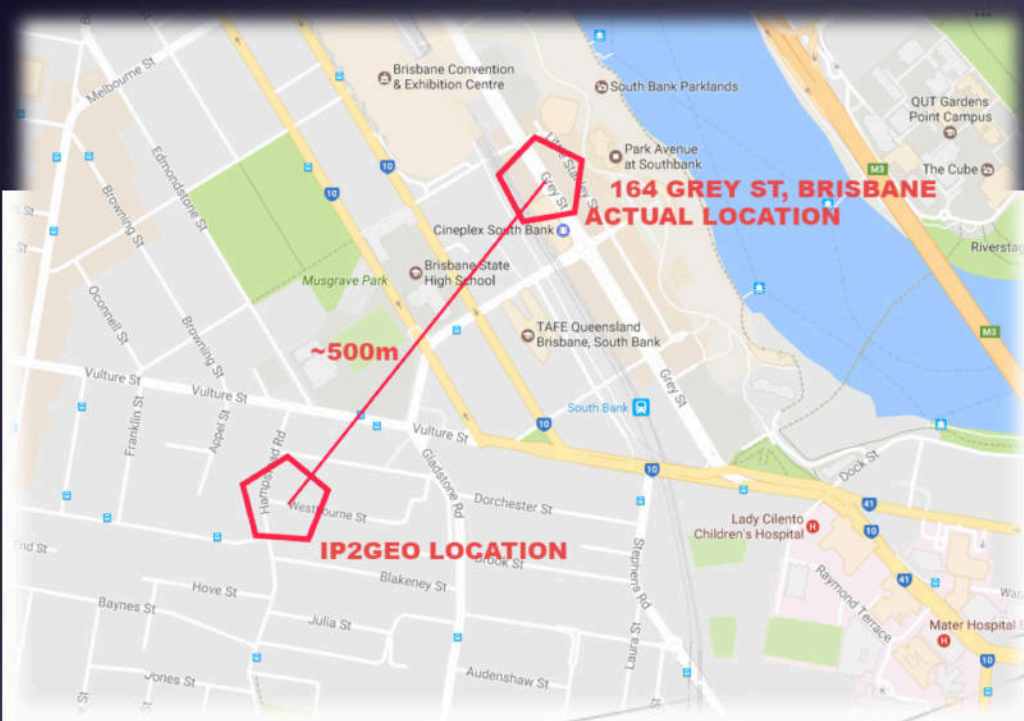
Demo: Hunting ICS devices automatically

- ▶ Category (eg “Power”, “Water”,etc)
- ▶ Gives us locations on a country level
- ▶ Gives us ICS devices for a country!

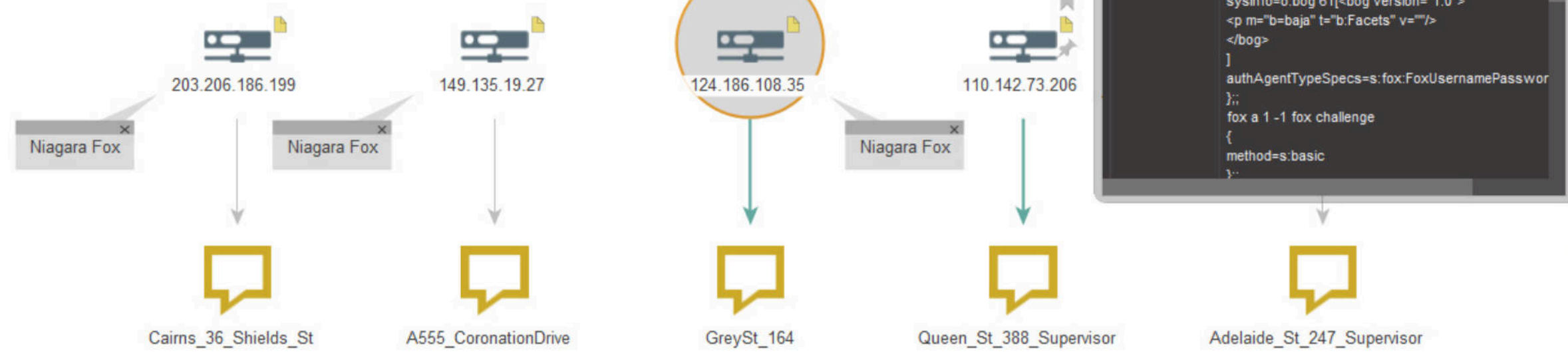
Hunting ICS Devices



- ▶ This relies on how good our GEO2IP is
 - ▶ Is it good?
 - ▶ “Sometimes”
- ▶ Denser Areas
 - ▶ Better GEO->IP
- ▶ Less populated areas
 - ▶ Worse, but is that okay?



city:brisbane



Breaches

- ▶ Footprinting ICS devices lets us find **interesting infrastructure** to target
- ▶ But what about people?
- ▶ What about people who work at **interesting places**

Breaches

- ▶ Breaches Happen.
- ▶ Breaches are often used to do basic audits of companies
 - ▶ How many employee's (based on our domain)
 - ▶ How many company cards
 - ▶ Etc etc
- ▶ Plenty of work is done on this already via the usual sources (blogs / "Big Data" white papers, etc)
- ▶ AshMad as an example ->

AshMad? Maltego MDS

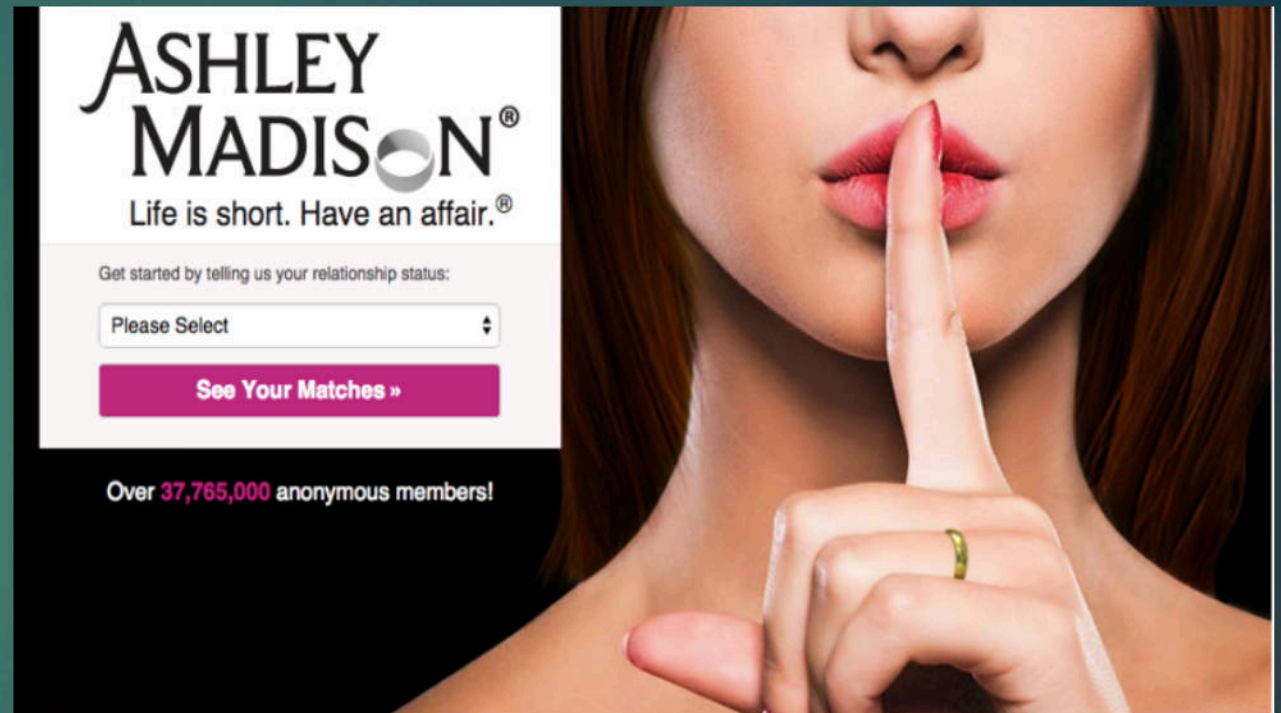
- ▶ Free Beta at the moment
 - ▶ I cant speak forever!
- ▶ Just one way you could get data in, others:
 - ▶ Public TDS (free!)
 - ▶ Local Transforms (free!)
 - ▶ Import Graph from Table (beer!)
- ▶ Requires:
 - ▶ Datasource (MySQL / Splunk / MSSQL / etc)
 - ▶ Query
 - ▶ Mapping
 - ▶ Takes each row returned and maps to entities

The screenshot displays the Maltego Data Server (MDS) interface, version Beta 1.2. The top navigation bar includes links for Datasources, Seeds, Transforms, Entities, Settings, Filters, Global Variables, Paired Configurations, Backup, and Workbench. The main content area is titled 'Transforms' and features an 'Add Transform' button. Below this, there is a 'Show All Seeds' dropdown and a 'Show 10 entries' indicator. A search bar is also present. The central part of the interface is a table listing transforms, with columns for Transform Name, Input Entity, Query, Mapping, and Opt. Three transforms are visible:

Transform Name	Input Entity	Query	Mapping	Opt
to Ashley Madison Member from IP	maltego.IPv4Address	Select pnum from aminno_member WHERE signuip1 = '\$\$E.value\$\$'	{E.Type=AM.Member; E.Value="\$pnum";} # use column name	[Settings] [Save] [Refresh] [Delete]
Ashley Madison Email Address	AM.Member	Select email from aminno_member_email WHERE pnum = \$\$E.value\$\$	{E.Type=maltego.EmailAddress; E.Value="\$email";} # use column name	[Settings] [Save] [Refresh] [Delete]
to Ashley Madison IP	AM.Member	Select signuip1 from aminno_member WHERE pnum = \$\$E.value\$\$	{E.Type=maltego.IPv4Address; E.Value="\$signuip1";}	[Settings] [Save] [Refresh] [Delete]

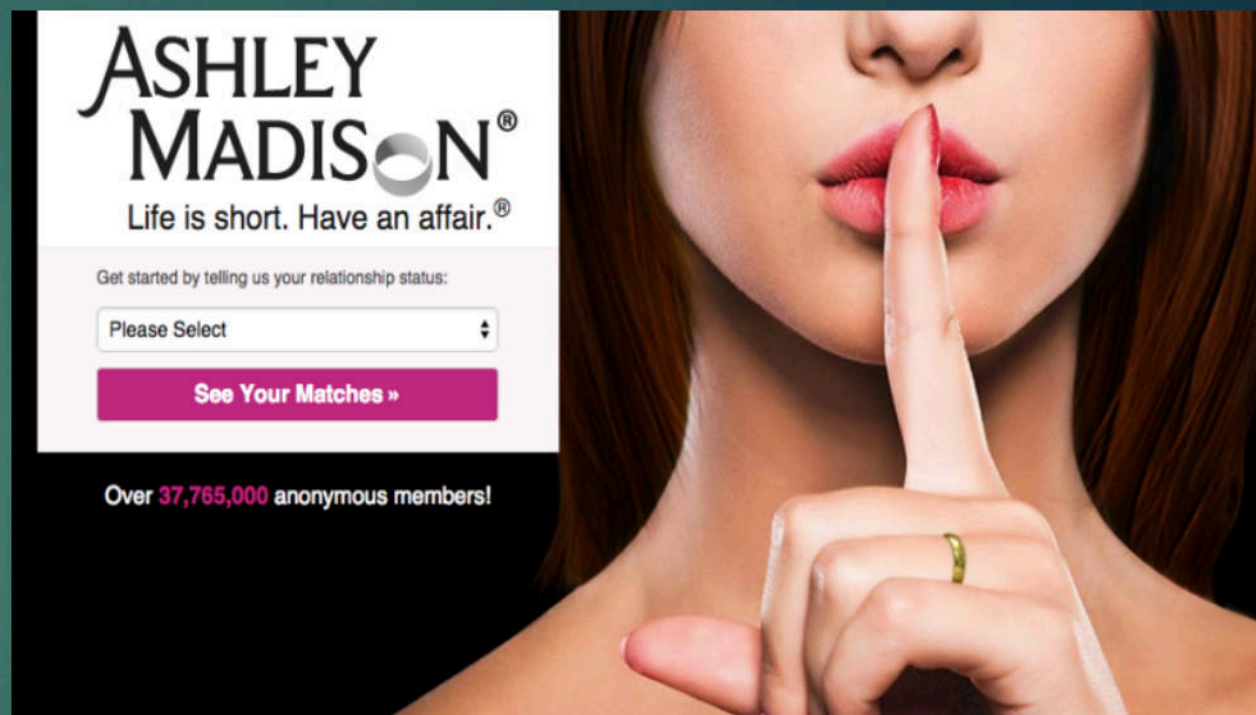
Fixing Ashley Madison dump

- ▶ Ashley Madison dump is great for doing email->profile
- ▶ But its not really good for doing:
 - ▶ Domain -> profiles
 - ▶ Slow, needs a new col referencing the domain
 - ▶ Limits subdomains (you'd need to know em)
 - ▶ IP Address -> profiles
 - ▶ 'signupip' field has lots of entries like '196.25.1.1,8'
 - ▶ Cant use like %% as its too slow
 - ▶ Netblock -> profiles
 - ▶ IP addresses are stored as strings
 - ▶ Need to convert to long
 - ▶ 68.171.1.1 - 68.171.255.255
 - ▶ 1152057601 - 1152122879



Ashley Madison dump

- ▶ We can interact with it as a “forward” method via
 - ▶ Domain -> profile
 - ▶ Email Address -> profile
 - ▶ Alias -> profile
- ▶ Users don't register work email accounts
 - ▶ (you'd think hey.. State.gov?)



Breaches for interesting targets

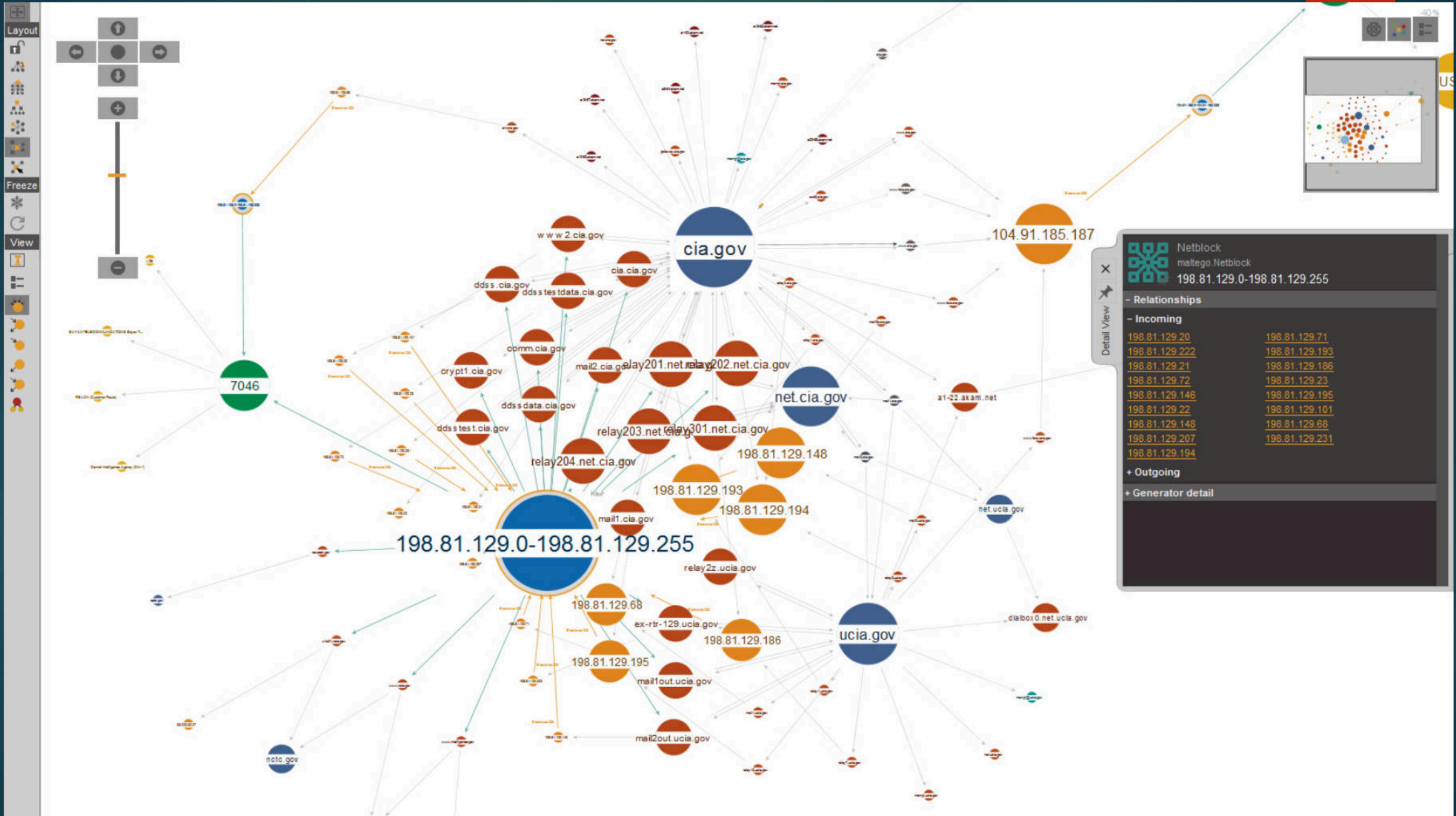
- ▶ But even if they do.. They definitely wouldn't use these sites from work computers right?
- ▶ Footprinting now becomes super interesting
 - ▶ Exit Nodes ->
 - ▶ Wiki Edits ->
 - ▶ Breach Data ->
 - ▶ (and the reverse!)

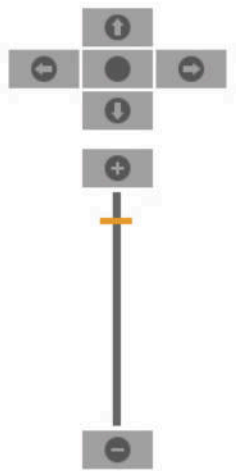


An Example

► CIA.gov







198.81.129.0-198.81.129.255



198.81.129.194

CIA exit node

IPv4 Address (254)

Entity		
198.81.129.1	100	
198.81.129.10	100	
198.81.129.100	100	
198.81.129.101	100	
198.81.129.102	100	
198.81.129.103	100	
198.81.129.104	100	
198.81.129.105	100	
198.81.129.106	100	
198.81.129.107	100	
198.81.129.108	100	
198.81.129.109	100	

URL (165)

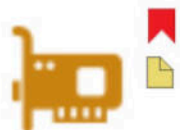
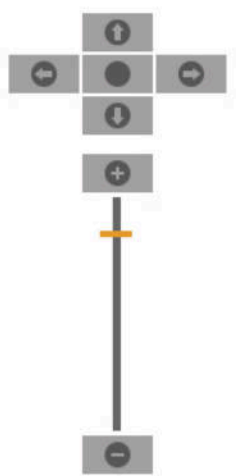
Entity		
Information privacy	100	
Information Sharing and Cust	100	
Intelligence operations in the	100	
Intellipedia	100	
Invisible College Press	100	
Iraq Intelligence Commission	100	
J. J. Watt	100	
J.C. King	100	
Jalal Talabani	100	
James B. Dudley	100	
Jeff Griffin	100	
John Harwood (journalist)	100	



Layout

Freeze

View



198.81.129.194

CIA exit node

- 1729 (number)
- 1992 Los Angeles riots
- 2003 invasion of Iraq
- 33rd Infantry Division (United...
- 540 Kick
- Acoustic cleaning
- Albert Haynesworth
- Alpha Kappa Psi
- Aluminium alloy
- Antanas Mockus
- Anthrax toxin
- Anti-Catholicism
- Arc-fault circuit interrupter
- Arthur Nowick
- Attack on German Flatts (1757)



0410@gmail.com

190%

Verification



2000 Mountain View, CA 94043, USA |

0410@gmail.com

Portfolio: <http://www.0410.com>

Work Experience

Applications Developer

November 2011 to Current

Central Intelligence Agency

McLean, VA

- Develop web applications with a Java Servlet back-end and an HTML5/CSS3/Javascript front-end.
- Manage Windows Server 2008 and Red Hat servers.
- Coordinate with clients to determine requirements and deadlines.
- Regularly present project ideas and results to non-technical audiences.

Shit happens...

GitHub Features Business Explore



0410

Block or report user

✉ 0410@gmail.com

eportfolio

My online portfolio website.

● PHP

weddingwebsite

A website I created for my upcoming wedding. It's the largest showcase of my Javascript expertise that I have -- I use jQuery heavily as well as the Google Maps API.

● HTML

 in Arlington, Virginia.

Started Working at Federal Government

2011 — Applications Developer
Arlington, Virginia

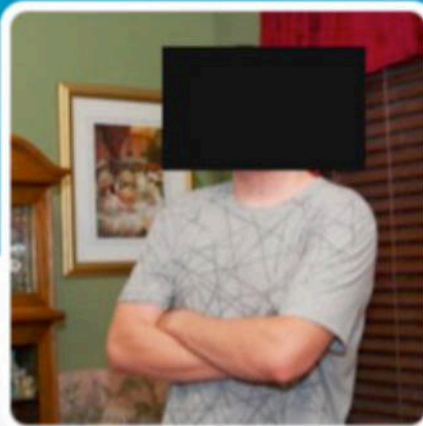
Branch: master ▼ eportfolio / php / config / gmail.ini

First commit.

0 contributors

7 lines (6 sloc) | 201 Bytes

```
1 ; this is a configuration file for Gmail, for secure emailing via PHPMailer.
2
3 [credentials]
4 smtp_url = "smtp.gmail.com"
5 username = "0410@gmail.com"
6 name = "0410"
7 password = "bori1089"
```



Your typical techie,

Earth

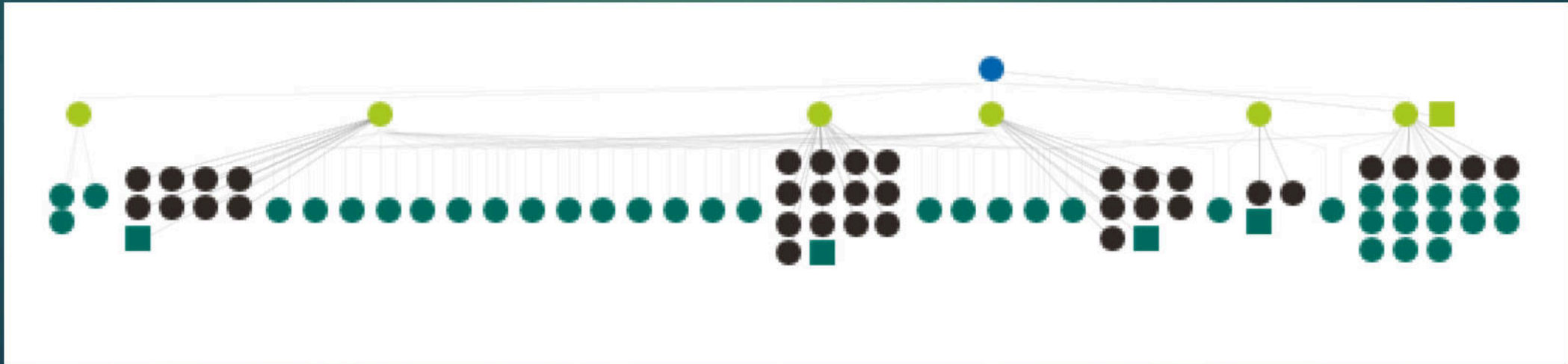
Joined November 2010

But...

- ▶ Profile seems too easy
 - ▶ User / Pass
 - ▶ Profiles
 - ▶ etc
- ▶ Honeypot? Could be..

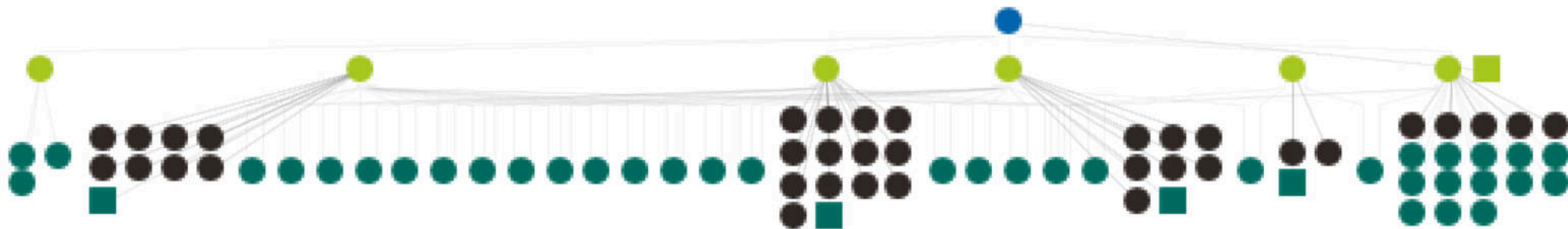
Other breaches?

- ▶ Friends at SocialLinks
- ▶ Many databases
- ▶ Lets see what that looks like with our current example...



Other breaches?

- ▶ Leaked databases/mail?
- ▶ Confirm our footprints!



More People!



- ▶ We found ICS devices via GPS
- ▶ Found people via footprinting + breaches
- ▶ What about people who work at interesting locations? (see 1.)

More People



3 Steps:

1. Find “interesting” places, the same way we did with ICS
 - ▶ Geonames + country
2. Use twitter to search for GPS
 - ▶ Geo/search
3. ???
4. Profit

GET geo/search

Search for places that can be attached to a statuses/update. Given a latitude and a longitude pair, an IP address, or a name, this request will return a list of all the valid places that can be used as the `place_id` when updating a status.

Conceptually, a query can be made from the user's location, retrieve a list of places, have the user validate the location he or she is at, and then send the ID of this location with a call to [POST statuses/update](#).

Conclusions



- ▶ ICS devices
 - ▶ Difficult to attribute
 - ▶ Usually not on the corp network / not visible to Internet
 - ▶ Easier to find on GPS, but this runs the risk of collateral (which might be okay)
- ▶ Breach Data
 - ▶ Gives a lot more than user details
 - ▶ Private email addresses (outside org) -> other social networks
 - ▶ Good for targeting people?
 - ▶ Exit nodes
 - ▶ Good for targeting infrastructure as they are likely to have both internal and external access

Thanks && Questions



- ▶ @AndrewMohawk
- ▶ Andrew@Paterva.com

